Administração de Sistemas ASIST

Tópico 3

Gestão de acessos

Gestão de acessos

- ***Network Access Control*** (**NAC**) é um conceito de controlo de acesso a uma infraestrutura pela implementação de políticas de segurança
- Tem como objetivos
  - Mitigar e/ou prevenir ataques *zero-day*
  - Aplicar uma política de segurança ao longo da infraestrutura
  - Usar identidades para realizar o controlo de acesso
- Estes objetivos podem ser alcançados através de vários mecanismos (políticas de segurança com definição de controlo de segurança, filtragem, prevenção, entre outros)
- O NAC vai atuar como um sistema de deteção e resposta automática que pode reagir em tempo real para impedir ameaças antes que causem danos

Gestão de acessos

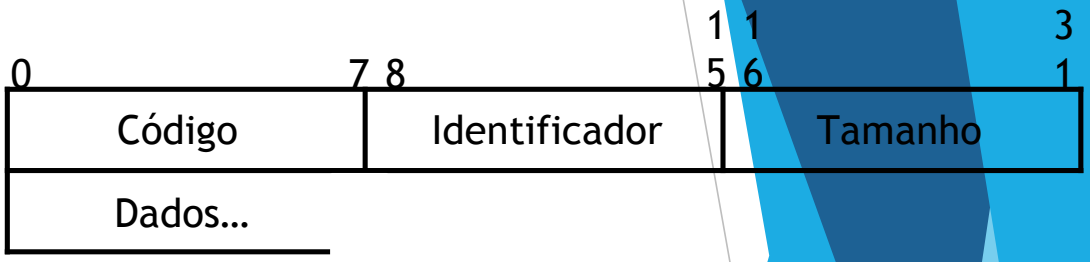
- O NAC pode ser implementado através de dois critérios ou mistura de ambos
  - Pré-admissão
    - Requer que um sistema cumpra todos os requisitos de segurança (tais como atualizações instaladas, antivírus atualizado) antes que possa comunicar com a rede
  - Pós-admissão
    - Permite ou nega acesso baseado na atividade do utilizador, que por sua vez é baseada numa matriz de autorizações previamente definida
- O critério *pré-admissão* refere-se a sistemas, serviços, e será objeto de análise mais tarde
- Já o critério *pós-admissão* é notório que envolve os utilizadores que acedem à rede
- E como é realizada a identificação dos utilizadores?

Gestão de acessos

- Os utilizadores representam os intervenientes de uma infraestrutura informática
- Necessitam de autenticação na infraestrutura para poderem tirar partido dos seus recursos
- A autenticação mais simples é denominada ***Password Authentication Protocol*** (**PAP**) e consiste na troca de duas mensagens no início do estabelecimento da autenticação
  - O utilizador envia a identificação e a senha
  - O sistema de autenticação valida o par identificação/senha
  - Devolve a autorização ou negação de acesso

Gestão de acessos

- Este método é considerado inseguro porque
  - A identificação e a senha são enviadas em texto claro (legível)
  - Não há proteção contra repetições ou falhas sucessivas
  - A identificação e a senha necessitam ser previamente definidas (segredo partilhado)
- O código representa a operação em curso
  - 1 – Authentication request
  - 2 – Authentication Ack
  - 3 – Authentication Nak

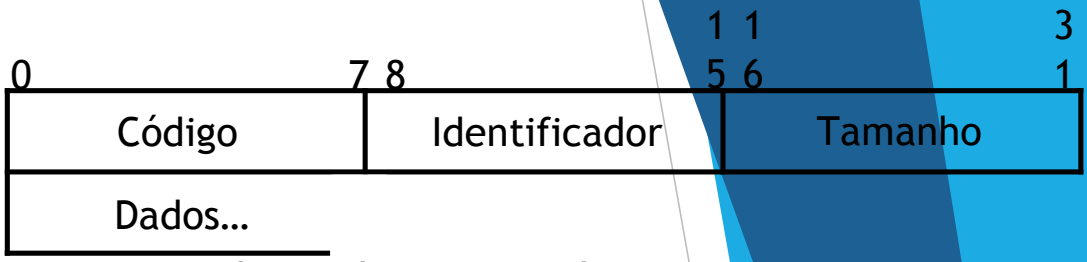


Constituição do campo *dados*

Tamanho da ID	Identificação
Tamanho da senha	Senha

Gestão de acessos

- Um método alternativo e mais seguro é aplicado pelo *Challenge-Handshake Authentication Protocol* (**CHAP**)
- Este protocolo utiliza um sistema de três mensagens e pode verificar periodicamente a identidade do utilizador
- Continua porém a ser necessária a definição prévia da identificação e da senha (segredo partilhado)
- O campo Código indica a operação em curso
- O campo Identificador é um número aleatório e serve para mapear os desafios e as respostas
- O campo Dados contém
  - O tamanho do texto de desafio ou resposta
  - O desafio (se código = 1) ou a resposta (se código = 2)
  - Um nome que identifica a o dispositivo que enviou o desafio



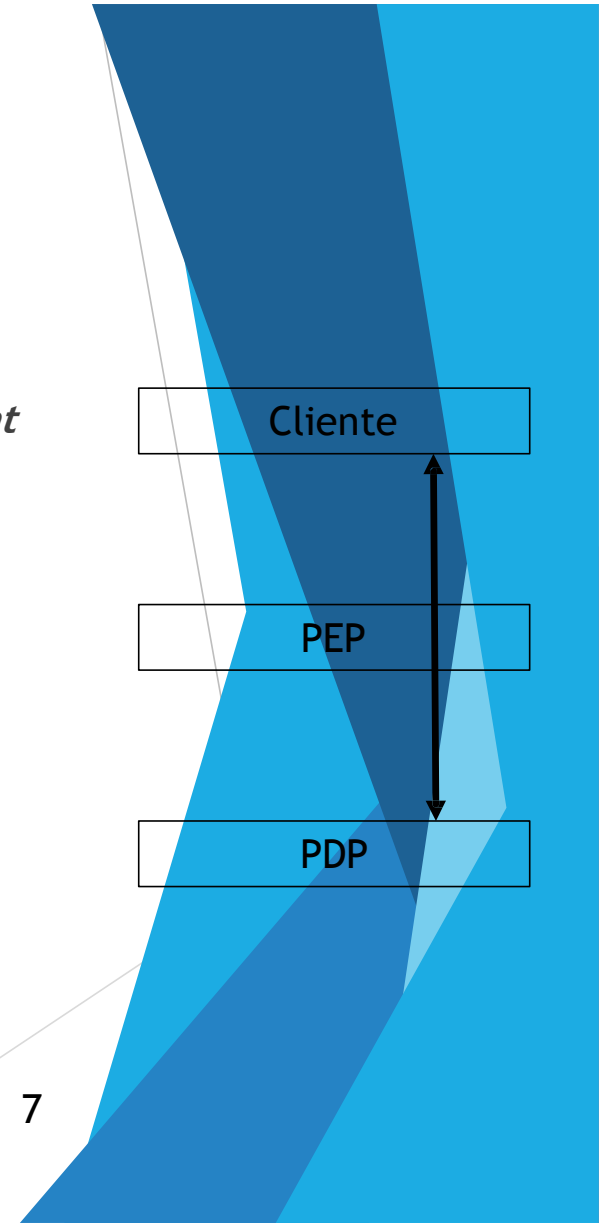
O desafio é um número aleatório gerado pelo serviço e ligado à senha
Varia de sessão para sessão



Coding (hex)	Meaning
01	Challenge
02	Response
03	Success
04	Failure

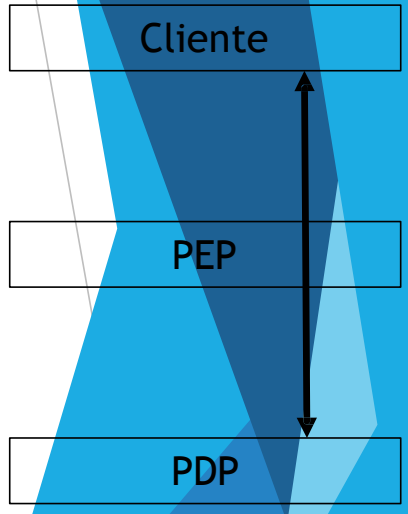
Gestão de acessos

- O ponto de acesso à rede é normalmente designado por ***Policy Enforcement Point*** (**PEP**) que, por sua vez, deverá:
  - Ou conter a identificação e credenciais dos utilizadores para validar o acesso
  - Ou contactar um ***Policy Decision Point*** (**PDP**) que se encarregará de validar as credenciais inseridas



Gestão de acessos

- Apesar de não ser especificamente um protocolo, convém olhar também para o ***Extensible Authentication Protocol*** (**EAP**)
- Na realidade é uma estrutura (*framework*) para autenticação
- Permite múltiplos sistemas alternativos na autenticação, como o uso de cartões, biometria, etc.
- Permite que o PEP funcione em modo *pass-through*, por exemplo quando a conexão é efetuada através de um ponto de acesso sem fios
- Na prática possibilita que o PEP seja transparente e a autenticação seja diretamente no PDP
- Vários mecanismos de segurança são possíveis de implementar recorrendo ao EAP, dos quais se destaca o ***Protected Extensible Authentication Protocol*** (**PEAP**) que encapsula o EAP num túnel ***Transport Layer Security*** (**TLS**)
- As normas ***Wifi Protected Access*** (**WPA**) incluem PEAP



Gestão de acessos

- Um dos mecanismos de autenticação mais utilizados baseia-se num segredo partilhado (como por exemplo uma senha de acesso)
- O segredo pré-partilhado enquadra-se na cifra simétrica, que veremos noutro tópico
- O segredo pré-partilhado garante a confidencialidade já que exige a chave para decifrar a mensagem
- Alguns autores consideram que este método não garante a autenticidade
  - Porque o segredo pode ser fraco ou obtido por engenharia social (à qual voltaremos noutro tópico)
- Para um segredo pré-partilhado ser efetivo, deve ser exclusivo de um par de entidades
  - Ou seja, para N entidades deverão existir $C_{(n,2)}$ (combinações de N dois a dois)

Gestão de acessos

- O elevado número de segredos conduz a problemas humanos
  - Como geramos e nos recordamos de um número enorme de segredos?
- Implica também a criação prévia do segredo – por exemplo, uma conta de utilizador
- Na prática, isto significa que uma entidade anteriormente desconhecida nunca se poderá autenticar
- Também num contexto prático, como partilhamos o segredo com uma entidade? Envio por SMS?

Gestão de acessos

- A autenticação das entidades insere-se na gestão de identidades ***Identity Management***
- Pode ser centralizada ou descentralizada
  - A autenticação descentralizada (também conhecida por controlo de acesso distribuído) implica que várias entidades localizadas ao longo do sistema ou infraestrutura executem a verificação do acesso
    - A sincronização é complexa e exige um elevado esforço administrativo
    - Os utilizadores têm a tendência de usar a mesma senha em todos os serviços e sistemas, ou a anotar as senhas em papel, com implicação direta na segurança
    - Contudo oferece vantagens no controlo de autorização de acessos
  - A autenticação centralizada exige menor esforço administrativo, não implica a sincronização das senhas, e as entidades necessitam de se autenticar apenas uma vez
    - Em suma, oferece o ***Single Sign-On*** (**SSO**)
    - Mas obriga a um esforço acrescido de autorização de acessos

Gestão de acessos

- Nas organizações é especialmente sentida a necessidade de assegurar a gestão centralizada dos utilizadores
- Um serviço de diretório consiste numa base de dados que inclui informação sobre objetos e entidades
- Vários desses serviços são baseados no ***Lightweight Directory Access Protocol*** (**LDAP**) RFC 3494
  - O Active Directory Domain Services da Microsoft, por exemplo, é baseado no LDAP
- O LDAP pode ser considerado uma evolução do protocolo X.500, suportando o diálogo com ele e mantendo várias das suas definições (como classes e atributos)
- Uma vantagem importante do LDAP é suportar a exportação de ramos da árvore (ou da árvore toda, claro!)

Gestão de acessos

- O LDAP (RFC 4511 na sua versão mais atual) é uma base de dados não relacional que pode alojar as autenticações das entidades
- A sua estrutura de dados é muito flexível e otimizada para operações de consulta
- A sua estrutura é em árvore, sendo cada ramo um **objeto** que possui **atributos**
- O topo da estrutura é designado por **root**
- Os atributos são indexados com o intuito de otimizar a pesquisa/consulta
- O cliente (humano ou sistema) acede ao diretório global (que pode conter vários servidores LDAP) através de um cliente ou ***Directory User Agent*** (**DUA**)
- Este cliente por sua vez interage com um ou mais servidores ou ***Directory System Agents*** (**DSA**) através do protocolo LDAP

Gestão de acessos

- O protocolo LDAP utiliza o TCP como mecanismo de transporte e baseia-se na ***Abstract Syntax Notation One*** (**ASN.1**)
- Todas as mensagens LDAP são encapsuladas num formato denominado ***LDAPMessage***, sequência em formato string que contém um número de sequência, um identificador, a operação pretendida e uma mensagem
- Caso uma mensagem em que o número de sequência não seja reconhecido, a conexão é terminada devolvendo uma indicação de desconexão com código de erro (**ProtocolError**) ao cliente
- Em todos os outros casos em que não seja possível ao cliente ou ao servidor analisar a mensagem, a conexão é de imediato terminada podendo ou não devolver uma mensagem ao outro extremo

Gestão de acessos

- A definição dos atributos dos objetos no LDAP tem que cumprir a definição do *schema* (definidos na RFC 4512) não sendo portanto livre
- O *schema* contém as classes possíveis contendo cada uma os atributos que são válidos e que tipo de utilização é permitida em cada um
  - Alguns atributos são obrigatórios, outros opcionais
- A definição das classes implementa o conceito de herança, pelo que uma classe ao ser subclasse de outra incorpora os atributos da hierarquicamente superiora, podendo na subclasse ser definidos mais atributos

Gestão de acessos

- Existem classes estruturais e auxiliares (contudo, opcionais)
- Cada objeto pertence a uma única classe estrutural, mas pode pertencer adicionalmente a várias classes auxiliares
- Entre os atributos obrigatórios encontra-se o ***Domain Component*** (**DC**) que pode pertencer à classe ***dcObject*** (que é auxiliar) normalmente conjugada com a classe estrutural ***Organization***
  - Alternativamente poder-se-á usar a classe estrutural **Domain**
- Tornou-se frequente a nomeação baseada no nome de domínio DNS, sendo cada uma das suas partes um **dc**, separados por vírgulas
  - DNS: **isep.ipp.pt**
  - root: **dc=isep,dc=ipp,dc=pt**

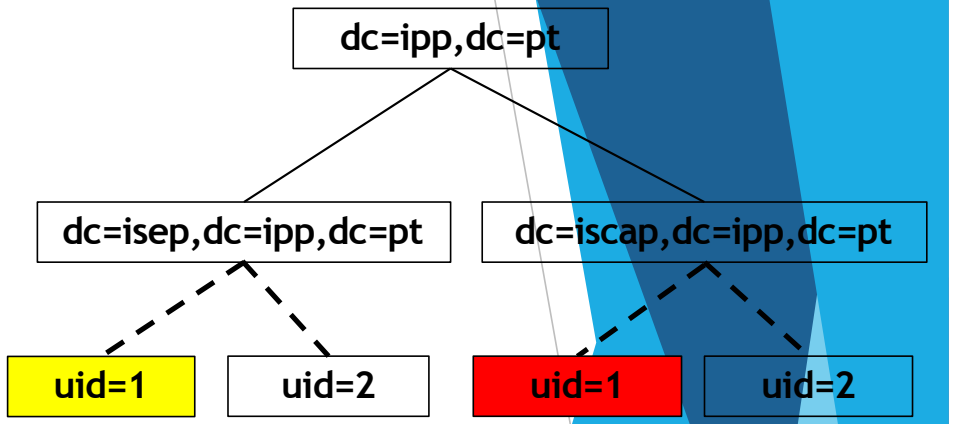
Gestão de acessos

- O nome que identifica um objeto único e exclusivo na árvore LDAP é um ***Distinguished Name*** (**DN**)
- Se o DN corresponde ao ***root***, designa-se por **base DN** ou **root DN**
- Um DN tem de ser único no LDAP identificando de forma inequívoca o objeto
- Os nomes dos atributos contudo podem ser repetidos ao longo da estrutura, desde que em ramos diferentes da árvore
- Distingue-se então os ***Relative Distinguished Names*** (**RDN**) que, sendo únicos e exclusivos no ramo em que se encontram, podem ser repetidos noutro ramo
- Na imagem, os objetos com RDN **1** têm o DN

  (com fundo amarelo) **uid=1,dc=isep,dc=ipp,dc=pt**

  (com fundo vermelho) **uid=1,dc=iscap,dc=ipp,dc=pt**

Sob dc=isep, dc=ipp, dc=pt só pode existir um uid=1, sendo um RDN, mas podem existir outros uid <> 1, tal como sob dc=iscap, dc=ipp, dc=pt

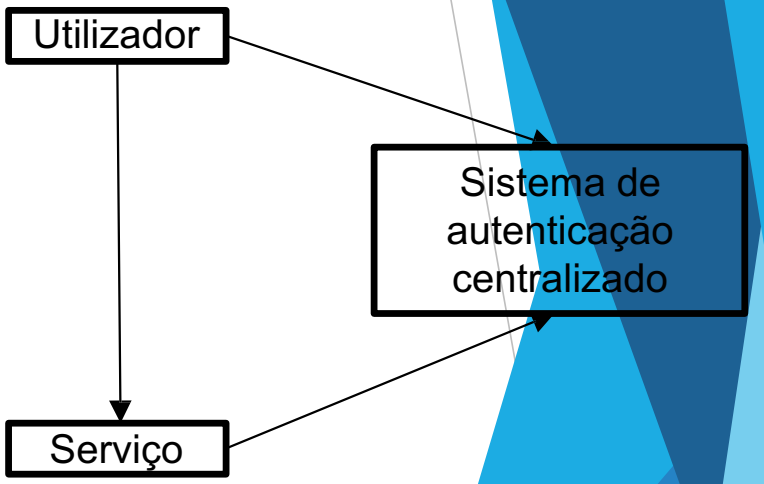


Gestão de acessos

- Quando uma entidade se autentica numa infraestrutura há uma sequência de passos necessários
- Em primeiro lugar, a **identificação**
  - Consiste em anunciar quem é a entidade (por exemplo, o nome de utilizador, ao qual chamaremos ID, e a senha de acesso)
- Depois, a **autenticação**
  - O sistema valida o par ID – senha
  - Devolve o sucesso ou insucesso da identificação
- Estes passos terão de ser efetuados para todos os serviços a quem o ID pretende aceder
- Mas ter-lhes-á acesso (autorização)?

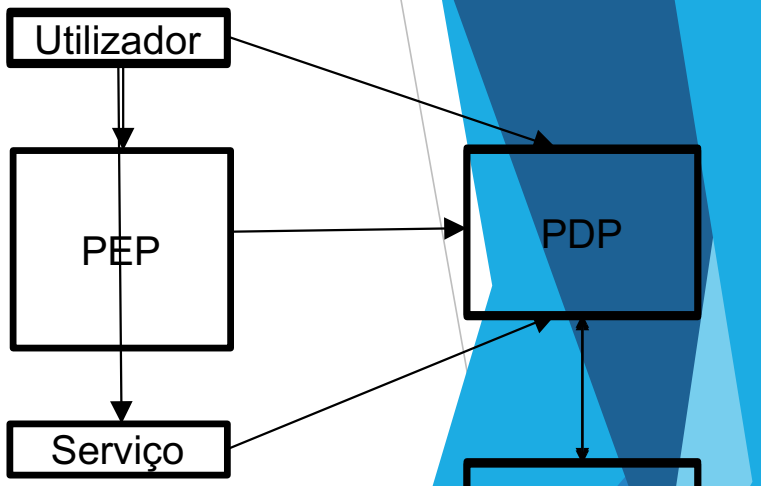
Gestão de acessos

- A **autenticação** refere-se a comprovar a identificação de quem se autentica
- A **autorização** refere-se a verificar se o ID pode aceder ao serviço
  - E, claro, só ocorre a quem já se autenticou com sucesso
- Torna-se assim clara a vantagem de ter um serviço centralizado de autenticação, já que permite que todos os serviços validem o utilizador
- Isto não implica porém que o utilizador tem autorização garantida a todos os serviços; implica é que o serviço pode validar o utilizador recorrendo ao serviço centralizado de autenticação



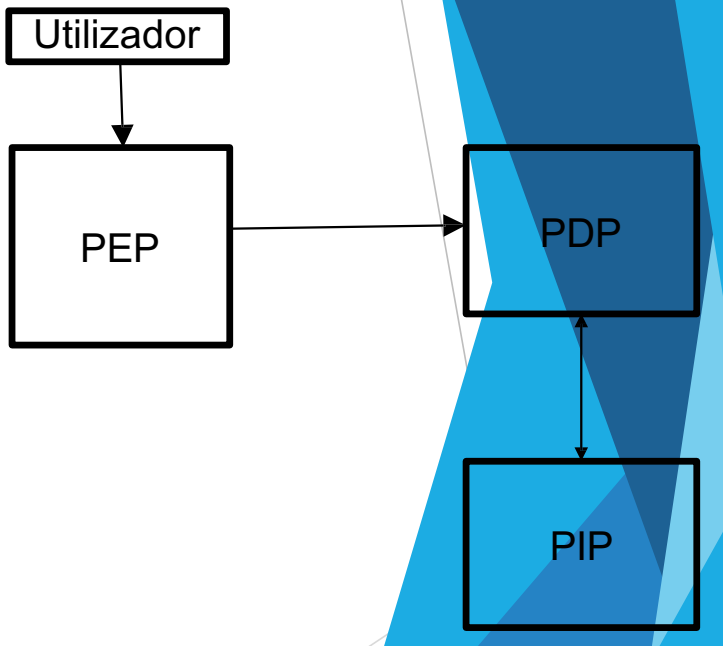
Gestão de acessos

- O serviço central de autenticação é habitualmente designado por ***Policy Decision Point*** (**PDP**)
- A validação da autorização concedida ao utilizador recorre a outro serviço centralizado, intimamente ligado ao PDP, designado por ***Policy Information Point*** (**PIP**)
- O utilizador normalmente não acede diretamente ao PDP mas a um serviço que se encarrega de contactar com o PDP
- A este serviço chama-se ***Policy Enforcement Point*** (**PEP**)
- O PEP é normalmente um serviço de rede, mas pode também ser um acesso por túnel VPN (a que voltaremos noutro módulo) ou um Access Point
  - Nesse caso denomina-se habitualmente por ***Network Access Service*** ou ***Network Access Server*** (**NAS**)

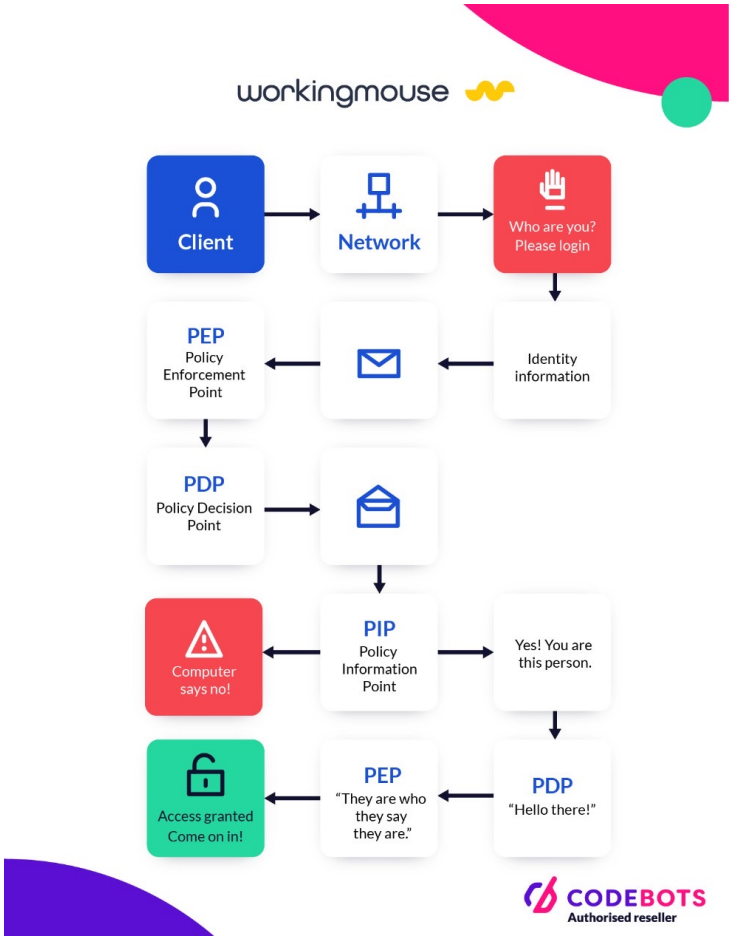


Gestão de acessos

- O serviço central de autenticação é habitualmente designado por ***Policy Decision Point*** (**PDP**)
- A validação da autorização concedida ao utilizador recorre a outro serviço centralizado, intimamente ligado ao PDP, designado por ***Policy Information Point*** (**PIP**)
- O utilizador normalmente não acede diretamente ao PDP mas a um serviço que se encarrega de contactar com o PDP
- A este serviço chama-se ***Policy Enforcement Point*** (**PEP**)
- O PEP é normalmente um serviço de rede, mas pode também ser um acesso por túnel VPN (a que voltaremos noutro módulo) ou um Access Point
  - Nesse caso denomina-se habitualmente por ***Network Access Service*** ou ***Network Access Server*** (**NAS**)



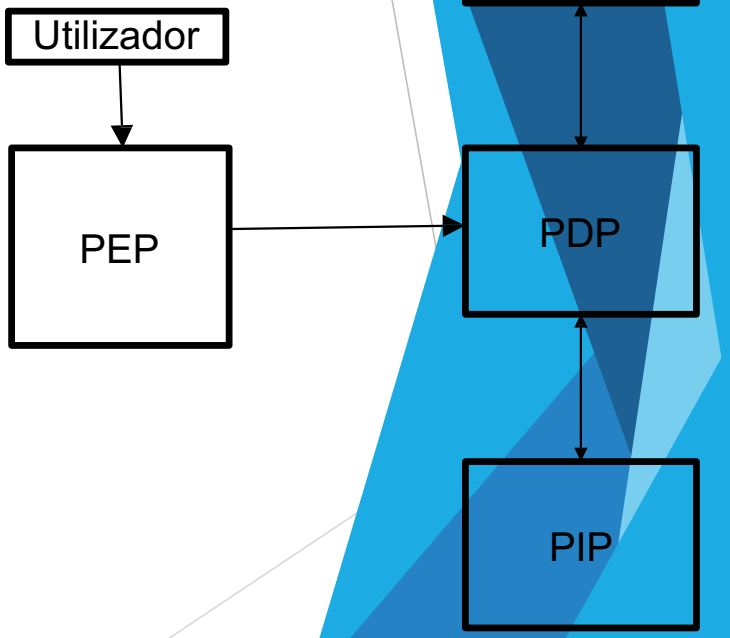
Gestão de acessos



Fonte: codebots.com

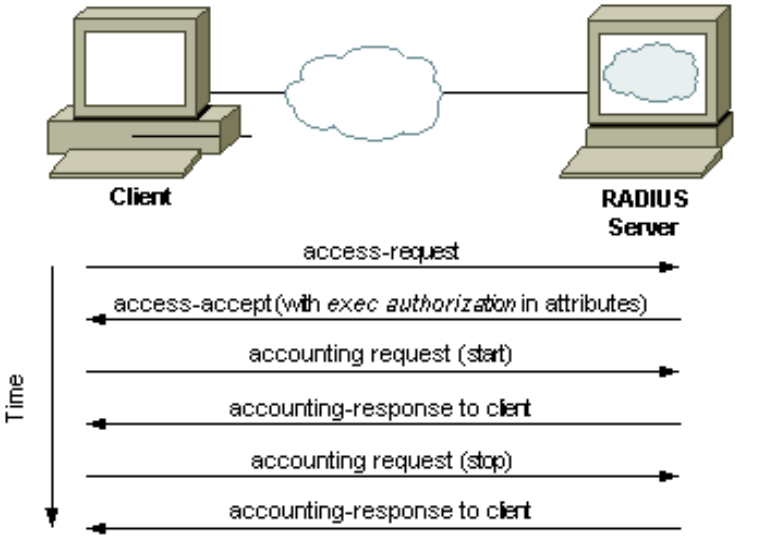
Gestão de acessos

- É normalmente necessário (seja para controlo interno seja para cumprir obrigações legais) o registo dos acessos concedidos e negados às entidades
- Este registo denomina-se ***Accounting*** e, juntamente com a ***Authentication*** e ***Authorization*** anteriores, constitui os sistemas **AAA**
  - ***AAA - Authentication, Authorization, Accounting***

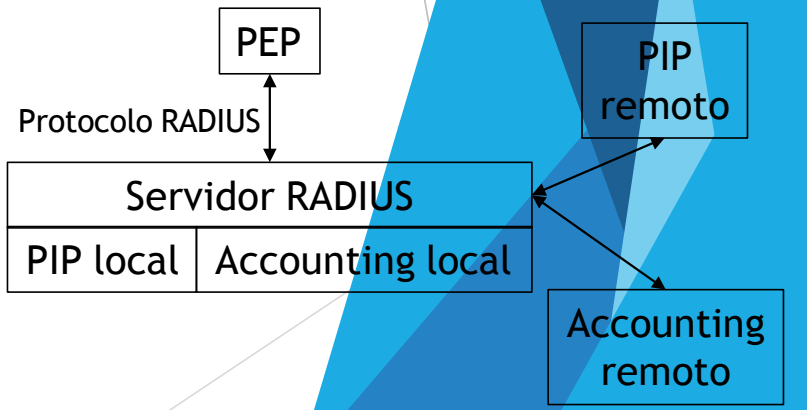


Gestão de acessos

- Foram desenvolvidos protocolos para assegurar o suporte ao AAA
- Entre estes, destaca-se o ***Remote Authentication Dial In User Service*** (**RADIUS**) (**RFC 2865**)
- O RADIUS é em simultâneo um serviço e um protocolo que assegura as comunicações entre o PEP e o PDP
- Esta comunicação ocorre em UDP para evitar constrangimentos associados ao TCP
- Pode ter um PIP e accounting local ou, através de extensões, comunicar com outros serviços que implementem essas funções
- No RADIUS os pedidos de accounting são registados apenas para o início e fim da sessão
- Usa 8 bits para definir os pares Atributo – Valor (AV)

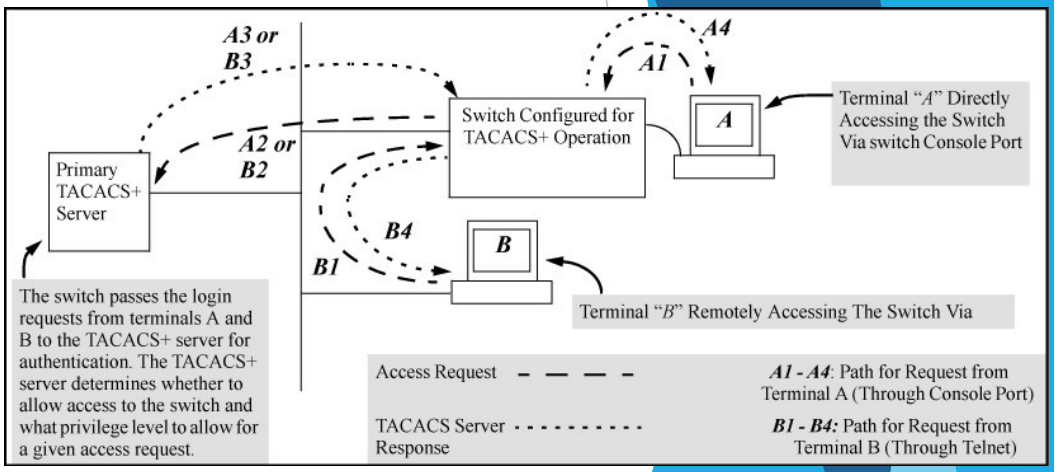


Fonte: cisco.com



Gestão de acessos

- Outro protocolo com suporta o AAA é o ***Terminal Access Controller Access-Control System Plus*** (**TACACS+**)
  - Evolução do TACACS e do XTACACS mas incompatíveis com eles
- Ao contrário do RADIUS usa TCP
- Uma diferença significativa é que o TACACS+ isola as verificações (autenticação e autorização) e repete a autorização sempre que a execução de um novo comando é requerida



Fonte: techhub.hpe.com

Gestão de acessos

- Mais recentemente, em 2003, surgiu uma evolução baseada no RADIUS embora não compatível com ele: o ***Diameter*** (RFC 6733 na versão atual)
- Como aspetos mais importantes,
  - Suporta o EAP
  - Suporta **SCTP** (***Stream Control Transmission Protocol***)
  - Permite mecanismos de *failover*
  - É baseado em TCP
  - Usa 32 bits para definir os pares Atributo – Valor (***Attribute-Value Pair*** **AVP**) sendo por isso mais escalável
    - Os AVP contêm informação de autenticação, accounting, autorização, encaminhamento, segurança e configuração para o pedido e resposta
  - Suporta redes cabladas, wifi, 3G, IP Multimedia Systems (IMS), e LTE/4G

Gestão de acessos

- Um método usado para suportar o AAA consiste em ter uma terceira parte que assegure a identificação e autenticação, fornecendo bilhetes (*tickets*) às entidades que os solicitem
  - Oferecendo o que é designado como ***ticket authentication***
- O sistema mais comum deste tipo é o ***Kerberos***

Gestão de acessos

- O **Kerberos** foi desenvolvido pelo MIT para uso interno, sendo mais tarde disponibilizado para uso externo
- A versão mais atual é a V5, descrita na RFC 4120
- Oferece uma solução de ***Single Sign-On*** (**SSO**) aos utilizadores e providencia proteção às credenciais de autenticação
- Foi desenhado para assegurar uma forte autenticação para aplicações cliente/servidor através do uso de criptografia de chave secreta
- Através de extensões descritas na RFC 4556 a autenticação inicial pode socorrer-se da ***Public Key Infrastructure*** (**PKI**), à qual voltaremos mais tarde

Gestão de acessos

- Cada uma das entidades a quem o Kerberos pode distribuir chaves designa-se por ***principal***
- O Kerberos divide a infraestrutura em ***realms***
- Cada *realm* contém obrigatoriamente o serviço de distribuição de chaves denominada ***Key Distribution Center*** (**KDC**)
- Todos os utilizadores e recursos (*principals*) estão registados no KDC, que mantém uma base de dados das chaves de todos
- O servidor de autenticação executa as funções do KDC, dois serviços distintos e paralelos
  - ***Authentication Service*** (**AS**)
  - ***Ticket Granting Service*** (**TGS**)

Gestão de acessos

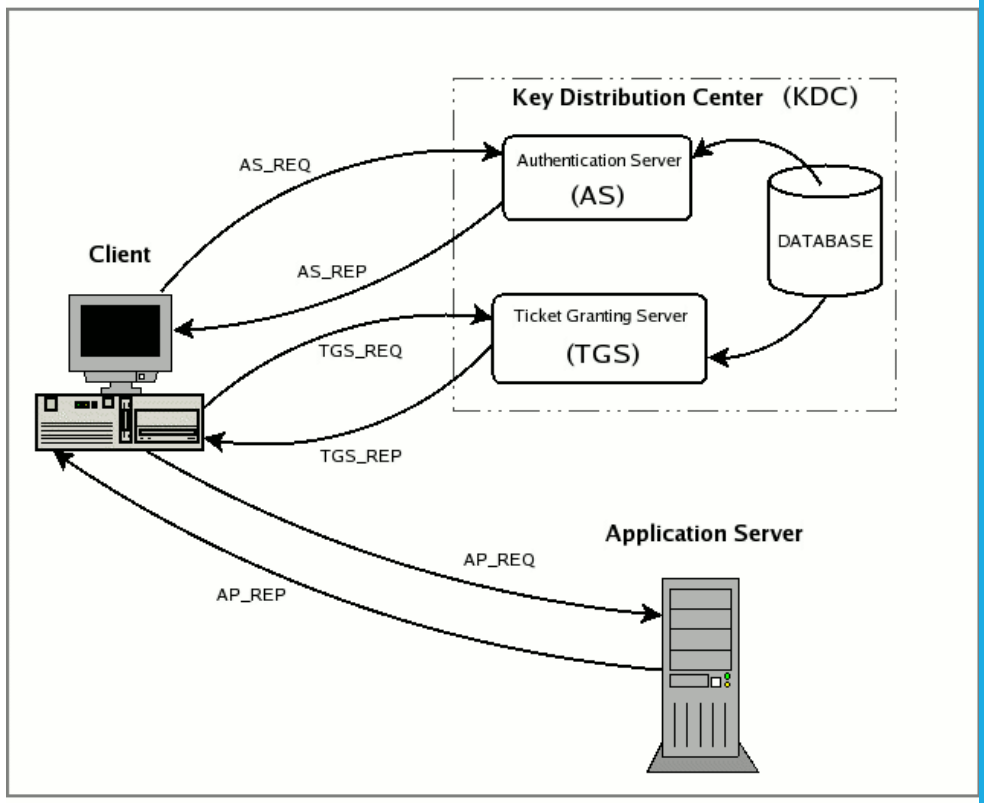
- ***Authentication Server*** (**AS**)
  - Possui uma chave partilhada com os *principals*
  - Aceita ou rejeita a tentativa de acesso
  - Fornece aos *principals* um *ticket* que lhes permite provar a sua identidade ao TGS
- ***Ticket Granting Service*** (**TGS**)
  - Fornece os ***Ticket-Granting tickets*** (**TGT**), chaves de sessão para comunicação temporárias, aos *principals*
  - Temporárias, pois o TGT tem um tempo de vida
  - Se não houver sincronização horária nos *principals*, o acesso será negado
  - O TGT prova que o *principal* se autenticou no KDC e está autorizado a pedir acessos aos recursos

Gestão de acessos

- Os *tickets* são mensagens encriptadas que provam a autorização de acesso a um recurso
- Um utilizador pede um *ticket* para aceder a um recurso, e se ambos (utilizador e recurso) estão autenticados e o utilizador tem permissão para utilizar o recurso, o Kerberos (mais exatamente o TGS) fornece-o
- Para além do tempo de vida, os *tickets* Kerberos possuem parâmetros de utilização específicos
- Quando um *ticket* expira o cliente deve solicitar a sua renovação ou um novo *ticket* para continuar a usar o recurso
- Estando todos os *principals* autenticados, assegura a toda a estrutura a identidade e autorização uns dos outros

Gestão de acessos

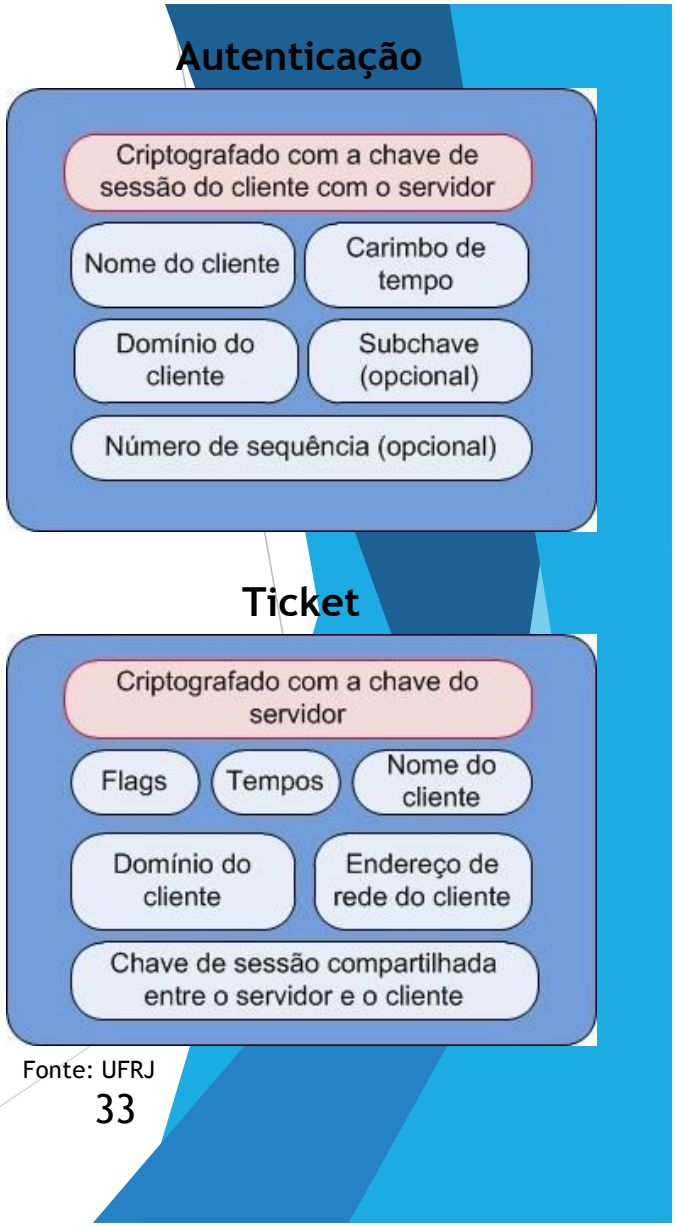
- Quando um *principal* se liga ao *realm* envia um pedido de autenticação ao KDC
- Sendo válida, é-lhe devolvido um Ticket-Granting Ticket (TGT)
- Quando o *principal* acede após a autenticação a um recurso da rede o TGT que recebeu é usado para pedir um outro *ticket* de acesso ao recurso
- Este novo pedido é enviado ao KDC que o valida



Fonte: kerberos.org

Gestão de acessos

- O processo de acesso no Kerberos tem o seguinte funcionamento
  1. O utilizador insere a autenticação no cliente
  2. O cliente encripta a autenticação e envia-a ao KDC
  3. O KDC verifica a autenticação na base de dados do AS
  4. O KDC gera uma chave simétrica para ser usada na comunicação; encripta-a com o *hash* da senha do utilizador; gera também um TGT encriptado
  5. O KDC transmite a chave simétrica e o TGT (ambos encriptados) ao cliente
  6. O cliente usa o TGT até expirar e decifra a chave simétrica com o seu *hash*

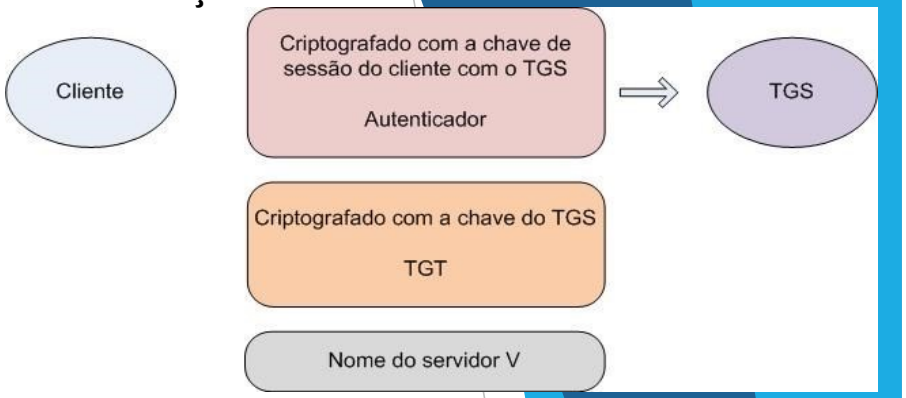


Fonte: UFRJ

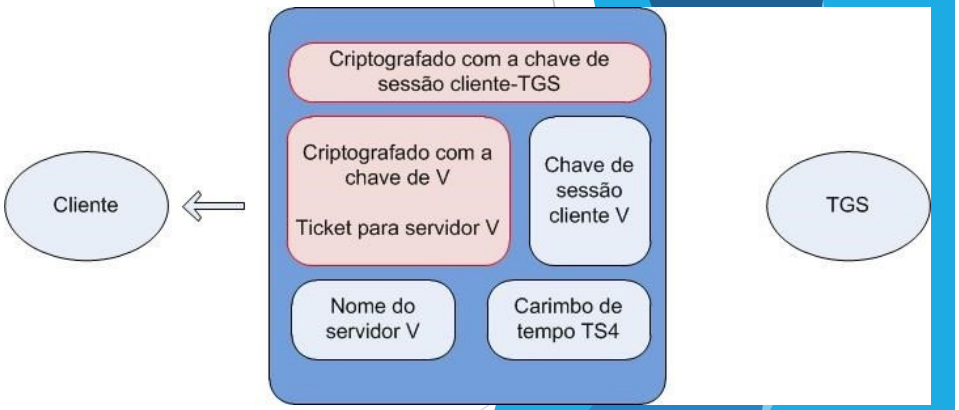
Gestão de acessos

- Quando um cliente quer aceder a um recurso, a sequência é
  1. O cliente envia o seu TGT ao KDC junto com o pedido de acesso ao recurso
  2. O KDC verifica a validade do TGT e se o cliente tem autorização para usar esse recurso
  3. O KDC gera um ticket de acesso ao recurso e envia-o ao cliente
  4. O cliente envia o ticket de acesso ao recurso ao servidor ou serviço onde o recurso está alojado
  5. O servidor ou serviço verifica a validade do ticket com o KDC
  6. Após verificação da identidade e autorização do acesso, a atividade do Kerberos está concluída
  7. O servidor ou serviço que aloja o recurso abre uma sessão com o cliente e a comunicação é estabelecida

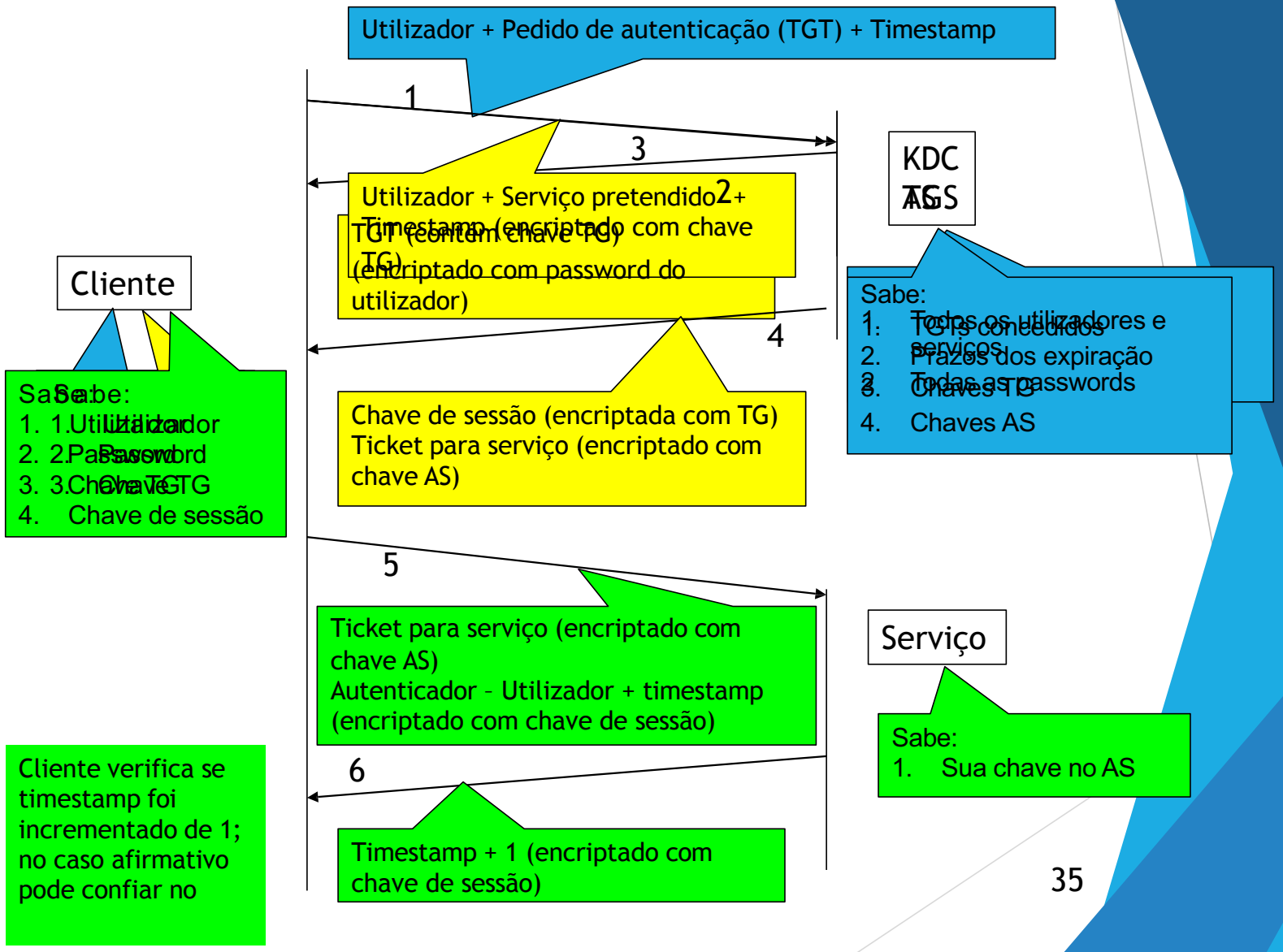
Solicitação de *ticket* de acesso a recurso



***Ticket* de acesso ao recurso**



Fonte: UFRJ


Utilizador + Pedido de autenticação (TGT) + Timestamp
1
3
2
Utilizador + Serviço pretendido + Timestamp (encriptado com chave TG)
TGT (contém chave TG) (encriptado com password do utilizador)
KDC
TGS
AS
Cliente
Sabe:
1. Utilizador
2. Password
3. Chave TGT
4. Chave de sessão
Sabe:
1. Todos os utilizadores e serviços
2. Prazos dos expiração
3. Todas as passwords
4. Chaves AS
Chave de sessão (encriptada com TG)
Ticket para serviço (encriptado com chave AS)
5
Ticket para serviço (encriptado com chave AS)
Autenticador – Utilizador + timestamp (encriptado com chave de sessão)
Serviço
Sabe:
1. Sua chave no AS
Cliente verifica se timestamp foi incrementado de 1; no caso afirmativo pode confiar no
6
Timestamp + 1 (encriptado com chave de sessão)

Gestão de acessos

- Os nomes dos *principals* num *realm* possuem reservas
  - O nome ***krbgt***, por exemplo, é reservado
  - Os símbolos **@** e **/** são usados para separar o nome do *principal* do nome do *realm* e componentes do nome do *principal* respetivamente
  - Exemplos são **user@realm** e **sftp/server@realm**

Gestão de acessos

- O Kerberos pode gerir relações de confiança entre *realms* distintos
- Com esta relação de confiança é possível a um *principal* de um *realm* aceder a recursos de um *realm* distinto sem necessitar de possuir credenciais no AS desse outro *realm*
- Este processo consiste em definir cada TGS como *principal* no outro *realm*
- Independentemente do *realm* em que se encontra, cada *principal* pode obter um *ticket* de acesso a recursos do outro *realm*
- Considera-se que um *realm* pode comunicar com outro *realm* se ambos partilham uma chave *inter-realm*
  - Esta chave será usada para encriptar os *tickets* de pedido de acesso a recursos do *realm* remoto

Gestão de acessos

- O Kerberos suporta também hierarquia entre *realms*
  - Um exemplo são os domínios Active Directory da Microsoft na mesma *tree*
- Havendo hierarquia, a relação de confiança é transitiva, isto é, se o *realm* A confia no *realm* B e o *realm* B confia no *realm* C, então o *realm* A confia no *realm* C

Gestão de acessos

- Como desvantagem do Kerberos, notar que o KDC é um SPOF
- As chaves baseiam-se nas senhas dos utilizadores, pelo que uma senha "fraca" potencia a sua captura e posterior acesso à chave
- O Kerberos não disponibiliza mecanismos de tolerância a falhas, pelo que é razoável configurar mais do que um KDC no mesmo *realm*, contudo:
  - A sincronização das bases de dados tem de ser feita com recurso a sistemas externos (automáticos ou manuais)
  - As aplicações deverão estar preparadas com base em tentativa-erro, isto é, se o KDC principal não responder, tentar no KDC alternativo e assim sucessivamente até obter sucesso ou falha após percorrer todos os KDC
    - Esta funcionalidade está contudo disponível no Active Directory da Microsoft
- Caso o KDC principal esteja inoperacional, a administração do Kerberos não pode ser efetuada até que ele seja restaurado